

TITLE: Password and Account Security Policy

ORGANIZATION: Northwind Analytics, Inc.

DEPARTMENT: IT

SENSITIVITY: Internal

VERSION: 2.0

EFFECTIVE_DATE: 2026-02-01

Password and Account Security Policy

This version supersedes v1.0. All corporate accounts now require a passphrase of at least 12 characters. The mandatory 90-day password rotation is removed in favor of MFA-backed continuous verification, in line with current NIST guidance discouraging frequent forced resets.

1. Password Requirements

Requirement	Standard
Minimum length	12 characters (passphrase)
Rotation	Removed -- replaced by continuous MFA verification

2. Multi-Factor Authentication

MFA (Okta Verify) is now mandatory for all corporate accounts and applications, not just finance and HR systems, effective immediately.

3. Account Lockout

Account Type	Lockout Threshold	Unlock Method
Standard account	5 failed attempts	Self-service via Okta Verify
Privileged / admin account	5 failed attempts	IT Helpdesk verification required

4. What Changed from v1.0

Area	v1.0 (2023)	v2.0 (Current)
Minimum length	8 characters	12 characters
Rotation	Every 90 days	Removed
MFA scope	Finance and HR only	All accounts and applications
Unlock method	IT Helpdesk only	Self-service (except privileged accounts)

5. Frequently Asked Questions

Do I need to change my current password to a 12-character passphrase immediately?

Yes, at your next login if your current password is shorter than 12 characters; the system will prompt you through the update.

Why was the 90-day rotation requirement removed?

Current NIST guidance finds that frequent forced password resets often lead to weaker, more predictable passwords (e.g., minor incremental changes). Continuous MFA verification provides stronger ongoing protection without that downside.

What if I'm locked out of a privileged/admin account?

Privileged and admin accounts still require IT Helpdesk verification to unlock, unlike standard accounts which can now self-service unlock via Okta Verify.

6. Contact

it-helpdesk@company.com

7. Note

Employees and systems still referencing the 90-day password rotation or the finance/HR-only MFA scope from the 2023 policy should disregard those requirements; this version is authoritative.